MODULE 23 · DOMAIN 6 - GOVERNANCE, RISK AND RESPONSIBLE USE

AI Policy and Governance

What a governance framework contains, following policy when it says no, admin controls, approved lists, and incidents.

DOMAIN 6 of 7 EXAM WEIGHT 15% MODULE 23 of 33

admin@sthithapragna.com

Governance is the **Highway Code** for AI: rules that let everyone travel faster, and safely.

What a governance framework contains

COMPONENT	WHAT IT ANSWERS	HIGHWAY CODE
Approved tools	Which AI tools and plans may be used	Approved vehicles
Allowed data	Which data classes may go where	Where you may drive
Required reviews	Which outputs need which checks	Speed limits and MOTs
Reporting paths	How to report incidents and concerns	What to do after an accident
Owners	Who decides, maintains and approves	The licensing authority

ON THE EXAM

Five components. A policy missing reporting paths or owners has nowhere to go when something breaks.

Halden's governance at a glance

- **Approved tool:** Claude Team is the only approved general AI tool.
- **Allowed data:** four classes; Restricted never goes into any AI tool.
- **Owners:** the AI review group (operations director, head of IT, data protection officer, HR partner) meets monthly.
- **Approved lists:** connectors and Skills, kept by IT. Technical builds go to IT and the partner.

> THE SIGNAL
>
> Every quirk in this course was settled by one of these pieces.

When the policy says no

01
Stop
Do not work around it.

02
Understand
Which rule, and why.

03
Find the approved route
Another tool, process or data set.

04
Request an exception
Through the owner, if nothing fits.

05
Record
What you did, and why.

ON THE EXAM

Never work around the policy. Work through it.

Admin controls on Team and Enterprise

CONTROL	TEAM	ENTERPRISE
Enable connectors, capabilities, project sharing	Owners	Owners
Organisation instructions for everyone	Owners	Owners
Usage analytics	Owners	Admins and Owners
Audit logs, custom data retention	-	Owners
Model access, custom roles, SSO	-	Yes

ON THE EXAM

On Team, the Owners hold the switches. Enterprise adds audit, retention and identity controls.

Organisation instructions: a fourth layer

- **Set by Owners** on Team and Enterprise plans; Claude follows them in every conversation in the organisation.
- **They win a direct conflict** with a person's own instructions.
- **Personal instructions still apply** wherever the organisation instructions are silent.
- **Use them for company-wide rules:** spelling, standards, compliance reminders.

> THE TIEBREAKER
>
> Company-wide rule: organisation instructions. Team rule: Project instructions. Personal preference: your own.

Approved lists

- **What goes on them:** tools, connectors, Skills, and the vendors behind them.
- **Why they exist:** so nobody has to judge security and data risk alone, under deadline.
- **Directory is not approval:** a connector in Anthropic's directory still needs your organisation's approval.
- **How to add something:** request it from the owner, stating the data it touches and the tools it needs.

> ON THE EXAM
>
> If it is not on the list, the answer is a request, not a download.

Incidents: what to do when something goes wrong

01
Contain
Stop; do not forward or reuse it.

02
Report
Through the named route, quickly, with the facts.

03
Investigate
The owner, with the data protection officer if personal data.

04
Fix the cause
Policy, instructions, training.

05
Share the lesson
With the teams affected.

ON THE EXAM

Report fast, and never hide it. Personal data breaches can carry a 72-hour reporting clock.

Governance traps

THE TRAP	WHY IT FAILS
A policy with no owners or reporting path	Nobody decides; nothing gets reported
Working around a "no" under deadline	The rule existed for exactly that moment
Treating directory listing as approval	Your data and policy still apply
Team rules in everyone's personal settings	Use organisation or Project instructions
Deleting the chat to hide a mistake	Hides the incident; the data was still shared
Waiting to see if harm follows	The reporting clock is already running

ON THE EXAM

Every trap replaces the system with an individual's guess.

> At 4pm on deadline day, a Halden bid writer hits her Claude usage limit. A colleague suggests a free AI chatbot he uses at home.
>
> Halden's policy says Claude Team is the only approved general AI tool.

What is the best response?

A Use the free tool just this once, given the deadline

B Paste the tender into a personal Claude account

C Stop work and accept that the bid will miss the deadline

D Stay within policy: switch to a lighter model, ask the Owner about extra usage, finish the rest by hand, and raise the capacity issue

◆ PAUSE AND DECIDE

What is the best response?

A Use the free tool just this once, given the deadline

Confidential tender data in an unapproved tool.

B Paste the tender into a personal Claude account

A personal account is outside the approved plan.

C Stop work and accept that the bid will miss the deadline

Gives up the goal when approved routes exist.

D Stay within policy: switch to a lighter model, ask the Owner about extra usage, finish the rest by hand, and raise the capacity issue

Follows the policy, and finds an approved route.

THE SIGNAL

The policy says no under deadline: work through it, not around it.

> A Halden account manager realises she pasted a client's staff list, including home addresses, into a Claude chat while drafting a rota proposal.
>
> Nothing has been sent to anyone yet.

What should she do first?

A Stop, do not reuse the chat, and report it straight away through the incident route, with what was shared

B Delete the chat and say nothing, since no one else saw it

C Ask Claude to forget the addresses

D Wait a week to see whether any harm results

◆ PAUSE AND DECIDE

What should she do first?

A Stop, do not reuse the chat, and report it straight away through the incident route, with what was shared

Contain, then report fast with the facts.

B Delete the chat and say nothing, since no one else saw it

Hides the incident; the data was still shared.

C Ask Claude to forget the addresses

A request is not a control.

D Wait a week to see whether any harm results

The reporting clock is already running.

THE SIGNAL

Personal data shared by mistake: contain, report fast, let the owner and DPO decide.

> A company Halden has just acquired is drafting its first AI policy. The draft covers approved tools, allowed data classes, and required reviews.
>
> Halden's operations director is asked what is missing.

Which two components are missing? Choose two.

A. A library of favourite prompts

B. Reporting paths for incidents and concerns

C. A complete ban on AI tools

D. Named owners who approve, maintain and decide exceptions

E. A list of current model version numbers

◆ PAUSE AND DECIDE

Which two components are missing? Choose two.

A A library of favourite prompts

Useful practice, not a governance component.

B Reporting paths for incidents and concerns

Without it, nothing gets reported.

C A complete ban on AI tools

Contradicts the approved-tools section.

D Named owners who approve, maintain and decide exceptions

Without them, nobody decides or maintains.

E A list of current model version numbers

Changes monthly; teach tiers, not versions.

THE SIGNAL

Tools, data, reviews are there: add reporting paths and owners.

A Claude-drafted client email went out with the wrong visit price, because the Project held an out-of-date rate card.

(1) Fix the cause: update the knowledge and the review checklist.

(2) Stop and contain: do not reuse the draft or the template.

(3) The owner investigates what happened and why.

(4) Report it through the named route, with the facts.

(5) Share the lesson with the teams that use the Project.

What is the correct order?

A 4, 2, 3, 1, 5

B 2, 3, 4, 1, 5

C 2, 4, 3, 1, 5

D 2, 4, 1, 3, 5

◆ PAUSE AND DECIDE

What is the correct order?

A 4, 2, 3, 1, 5

Reports before stopping further damage.

B 2, 3, 4, 1, 5

Investigates before anyone has reported it.

C 2, 4, 3, 1, 5

Contain, report, investigate, fix, share.

D 2, 4, 1, 3, 5

Fixes before knowing the cause.

THE SIGNAL

Contain, report, investigate, fix the cause, share the lesson.

> Halden's AI review group wants two rules followed in every Claude conversation across the company: British spelling, and never naming clients in marketing drafts.
>
> Halden is on the Team plan.

What is the best way to apply these rules to everyone?

A. Ask every employee to add the rules to their own Instructions for Claude

B. Have an Owner set them as organisation instructions, which apply in every conversation

C. Put the rules in one shared Project's instructions

D. Turn on Memory and tell Claude to remember the rules

◆ PAUSE AND DECIDE

What is the best way to apply these rules to everyone?

A Ask every employee to add the rules to their own Instructions for Claude

One hundred and eighty copies, some never added.

B Have an Owner set them as organisation instructions, which apply in every conversation

A company-wide rule in the company-wide layer.

C Put the rules in one shared Project's instructions

Only covers chats inside that one Project.

D Turn on Memory and tell Claude to remember the rules

Personal recollection, not a company control.

THE SIGNAL

Every conversation, company-wide: organisation instructions, set by an Owner.

> Halden's marketing manager finds a connector for a social-media scheduling tool in Anthropic's connector directory.
>
> It is not on Halden's approved connector list.

What should she do?

A Connect it, since a listing in Anthropic's directory means it is approved

B Connect it read-only without telling anyone, to keep the risk low

C Ask a colleague at another company whether it is safe

D Request it through the AI review group for the approved list, stating the data it would touch and the tools needed

◆ PAUSE AND DECIDE

What should she do?

A Connect it, since a listing in Anthropic's directory means it is approved

Directory listing is not organisational approval.

B Connect it read-only without telling anyone, to keep the risk low

Read-only is safer, but it bypasses the approval route.

C Ask a colleague at another company whether it is safe

Another company's policy is not Halden's.

D Request it through the AI review group for the approved list, stating the data it would touch and the tools needed

Not on the list: request it, with the facts.

THE SIGNAL

Not on the approved list: the answer is a request, not a download.

In five lines

- **Five components:** approved tools, allowed data, required reviews, reporting paths, owners.
- **When the policy says no:** stop, understand, find the approved route, request an exception, record.
- **Team Owners hold the switches;** Enterprise adds audit logs, retention, roles and model access.
- **Organisation instructions** apply company-wide and win direct conflicts.
- **Incidents:** contain, report fast, investigate, fix the cause, share the lesson.

COMING UP

Next: ethics, fairness, transparency and accountability.